

The Cartographer Framework

Report Interpretation

Report Interpretation Guide

Informational Guide for Interpreting Findings

TABLE OF CONTENTS

1.	Section A - Introduction	
	What is CAIRS?	03
	Calculating a CAIRS Score	04
2.	Section B – Interpreting Graphs	
	Layer 1 Graphs – Basic Rankings	05
	Layer 2 Graphs - Divergences	06
	Layer 3 Graphs – Comparison	07
3.	Section C – Severity Categories	
	Category 1 Severity - Flaws	08
	Category 2 Severity – Low Levels	09
	Category 3 Severity - Vulnerabilities	10
	Category 4 Severity - Criticals	11
4.	Section D – Fault Localization	
	Input Processing	12
	Function Processing	13
	Output Processing	14
	Model Hardening	15
	System Monitoring	16
5.	Section E - Conclusion	
	Post-Word	17

Reading a CAIRS Score

A CAIRS score will produce three values: SI, RC, and a Composite. These values will tell you the degree of impact relevant to their purpose.

The Composite Score will inform parties about an overall severity of a finding. The composite score will tell parties “how severe is this finding, how much effort is necessary to remediate this, what location is this finding likely affecting?”. This will be the first score to consider upon discovering a finding.

The Severity Index Score will inform parties about the magnitude of compromise for a given finding, pertaining to the traditional attack cycle. This score will determine if the given finding will require intervention by Legal, Public Relations, and other Administrative parties (more than engineering) due to the impact. Interpret this score as an anchor for where to send items in a ticketing system, and at what priority. The higher severity of the finding, the higher priority of the ticket.

The Remediation Complexity Score will inform parties about the magnitude of effort required to remediate the compromise associated with the finding at hand. This score will determine who should be involved in the mitigation efforts associated with this finding. It will define whether to bring an external contractor to remediate your system or your entire team to remediate your system. Utilize this score as a driving force behind delegating actors to mitigation efforts involved with remediating findings.

Calculating a CAIRS Value

Assign Progression Values

Fault Locality and Category Severity are rated on a scale from 1-5, and 0-4, respectively. Assign Progression values by instantiating Progression Values as F_Norm and C_Norm.

F_Norm

C_Norm

Define Progression Values

Progression Values are defined as follows:

$$C_Norm = (Category - 1) / 3$$

$$F_Norm = (Fault\ Layer - 1) / 4$$

Calculate Severity Index (SI)

Calculate the Severity Index with the below formula:

$$SI = 10 \times C_norm \times (1 + 0.2 \times F_norm)$$

Calculate Remediation Complexity (RC)

Calculate the Remediation Complexity with the below formula:

$$RC = 10 \times F_norm \times (1 + 0.3 \times C_norm)$$

Calculate CAIRS Composite Score

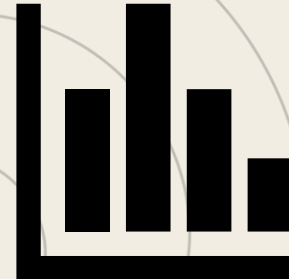
Use the Geometric Mean to calculate a Composite CAIRS Score:

$$CAIRS = SI^{0.65} \times RC^{0.35}$$

Layer 1 – Basic Rankings

What are Layer 1 Graphs?

Layer 1 Graphs are graph types used to visualize the basic rankings of findings. The Layer 1 Graphs consist of Horizontal Bar Charts and Grouped Bar Charts. These graphs measure the overall compromise rate across: Models, AML.T00NN Threat IDs, Red Team Technique Types, Red Team Technique Typologies.

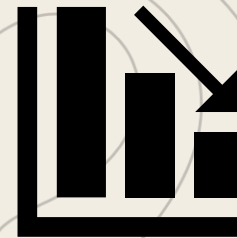


What does this Layer tell us?

These tell us the success rate for compromise individually, and the success rate of compromise when testing multiple models.

How does this information benefit stakeholders?

This information is a visual aid for a given test regarding “what happened”. The associated graphs answer questions regarding “which model is most at risk?”, “which attack types are more impactful than others?”, and “where is our compromise concentrated?”.



Layer 2 – Divergence

What are Layer 2 Graphs?

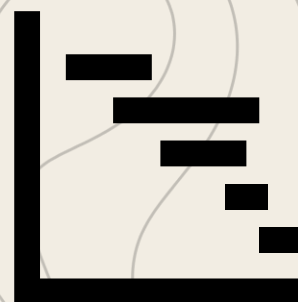
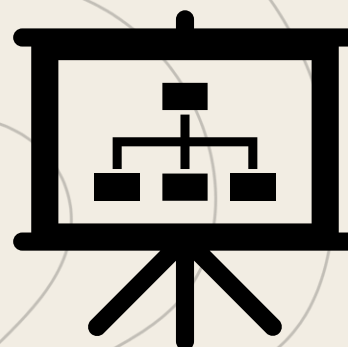
Layer 2 Graphs are graph types used to visualize variance of outcome, and quantify the uncertainty of outcome. This is achieved through Dumbbell Charts, which identify the contrast of variables relevant to findings.

What does this Layer tell us?

These graphs point to the likely fault locality of a given finding. Layer 2 Graphs consider the rate of compromise across models per red team technique, Threat ID, attack type, and attack category. The greater the divergence displayed the greater likelihood the finding requires Model Level remediations. The lower the divergence displayed, the greater likelihood the finding requires System Level remediations.

How does this information benefit stakeholders?

This information helps clients prioritize remediation: attack types with wide spread are worth spending engineering time on model-switching or fine-tuning, while narrow-spread ones need systemic fixes. It informs the involved parties of the expected resources required to remediate a given finding.



Layer 3 – Comparisons

What are Layer 3 Graphs?

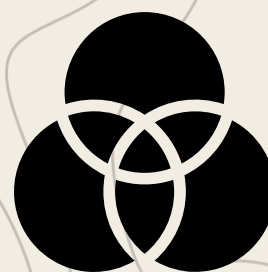
Layer 3 Graphs are graph types used to visualize the progress of remediation for a given finding. These graph types are Paired Dot Plots, and Grouped Bar Charts.

What does this Layer tell us?

These graphs inform operators about the change in Security Posture per remediations applied to a system impacted by a finding. Both charts quantify whether or not a change to an AI/LLM Model or Host System reduced the rate of compromise created by a particular attack surface.

How does this information benefit stakeholders?

This information provides Stakeholders with data that defends best effort security attempts. Furthermore, it reduces liability by tracking, gauging, and depicting the outcomes associated with remediation efforts. These graphs inform Stakeholders with information that answers questions “Have our Remediation efforts worked?”, “Will our Remediation efforts work?”, “How do we visualize the change in Remediation efforts?”. This is information gathered which contributes to the conclusion of your proactive, reactive, and corrective security efforts for your AI/LLM model and Host System.



Category 1 – Flaw Level

What is a Category 1 Vulnerability?

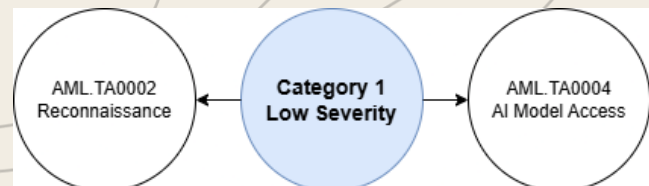
Category 1 is a Severity Category of flaws defined by low impact flaws that are easily remediated.

How does this information benefit stakeholders?

When testing findings suggest Category 1 Low Severity Flaws, it implies that there is a very low impact to the system hosting your model.

How is this category defined?

This category is defined by its attributed tactics: AML.TA0002 Reconnaissance and AML.TA0004 AI Model Access.



How do these tactics influence severity?

The Tactics within this Severity Category can be mapped to stages in a traditional attack cycle for a given adversary. These tactics reside in the early stages of any given attack cycle. The information retrieved here is generally of little impact, and easily remediated.

Category 2 – Low Impact

What is a Category 2 Vulnerability?

Category 2 is a Severity Category of flaws defined by Low Impact Vulnerabilities that are remediated with medium effort.

How is this category defined?

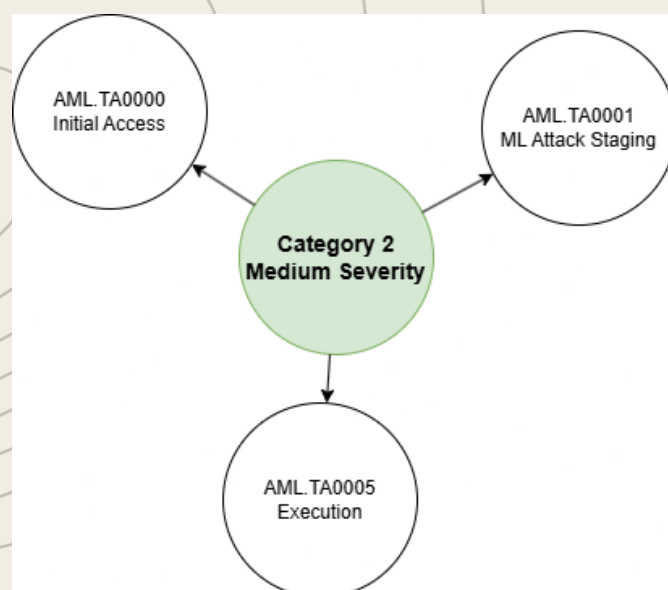
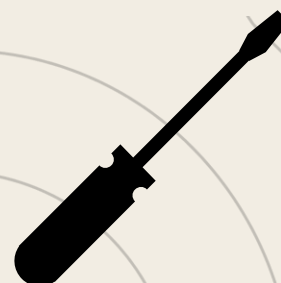
This category is defined by its attributed Tactics: AML.TA0000 Initial Access, AML.TA0005 Execution, AML.TA0001 ML Attack Staging.

How do these tactics influence severity?

The Tactics reside in transitory stages of the attack cycle. These tactics range from late-stage reconnaissance to initial access. Information retrieved here implies that the methods of exfiltration occur from a mechanism native to your system, by an external user, retrieving documents or information only intended for privileged users.

How does this information benefit stakeholders?

This Severity Category provides information regarding the state of compromise pertaining to an attack surface permitting access gain. Identifying surfaces such as these is critical in managing the security posture of your system.



Category 3 – High Impact

What is a Category 3 Vulnerability?

Category 3 is a Severity Category of Vulnerabilities defined by Threat's pertaining to the middle-to-end stages of the attack chain.

How is this category defined?

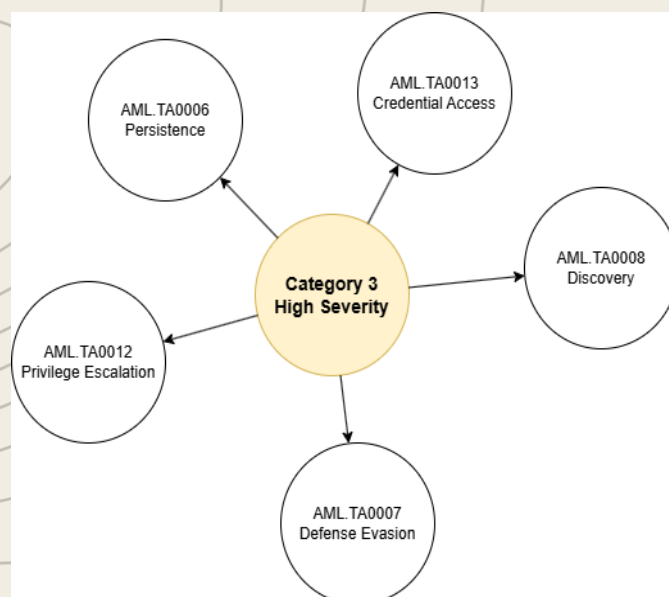
This category is defined by its attributed Tactics: AML.TA0006 Persistence, AML.TA0012 Privilege Escalation, AML.TA0007 Defense Evasion, AML.TA0013 Credential Access, and AML.TA0008 Discovery

How do these tactics influence severity?

These tactics all represent possible approaches to post-exploitation efforts. The success of Post-Exploitation Tactics implies the presence of a severe vulnerability on your system. Threat IDs identified at this level imply that your system has likely been compromised.

How does this information benefit stakeholders?

This Severity Category provides information regarding the state of compromise pertaining to an attack surface permitting access gain. Identifying surfaces such as these is critical in managing the security posture of your system.



Category 4 – Critical Severity

What is a Category 4 Vulnerability?

Category 4 Severity is a critical-severity vulnerability level defined by tactics sitting at the full compromise stage of the attack chain.

How is this category defined?

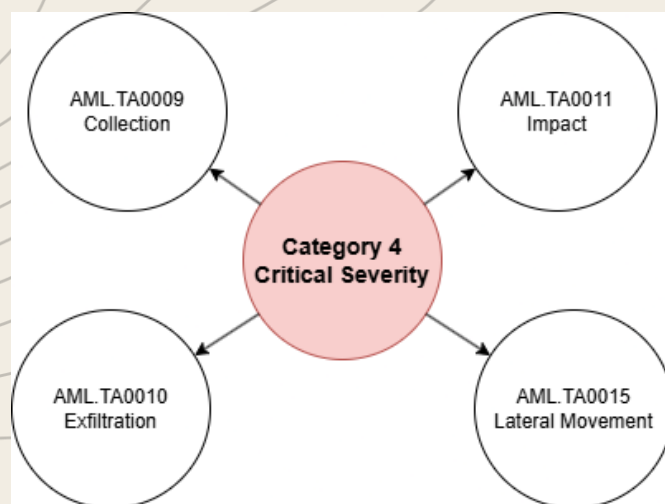
The Tactics attributed to this category are as follows: AML.TA0009 Collection, AML.TA0010 Exfiltration, AML.TA0011 Impact, and AML.TA0015 Lateral Movement.

How do these tactics influence severity?

The tactics here influence the rating of this category as they represent the end stages of a given attack cycle. The Threat IDs associated with these Tactics imply that a state of compromise is achievable to a degree that achieves total control over your system, through the AI Model or the underlying system hosting it.

How does this information benefit stakeholders?

The remediation path at this stage extends beyond your AI system — it requires a full incident response engagement, legal notification review, and a root-cause analysis of every prior category finding that enabled this level of compromise to occur.



Input Sanitization

What is this category?

Input Sanitization remediation efforts are those which occur for threats that exist against input receiving processes on a given AI/LLM powered system.

What Mitigation IDs are associated with this category?

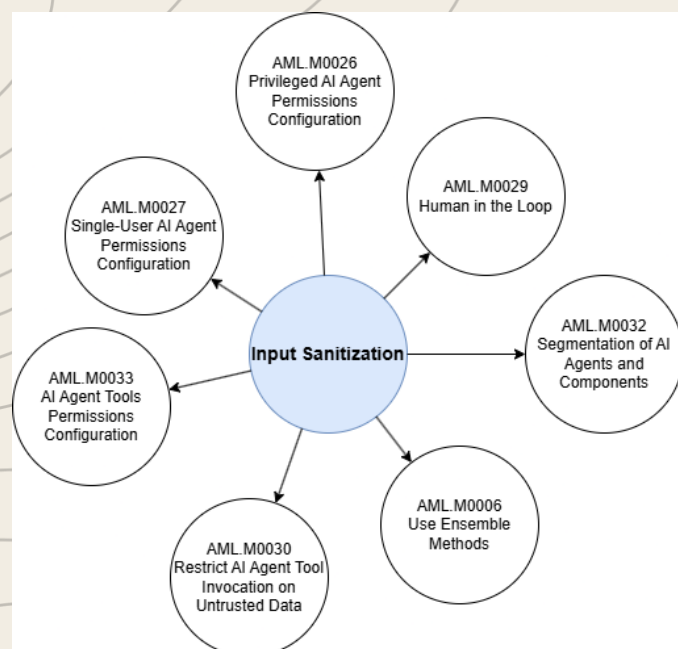
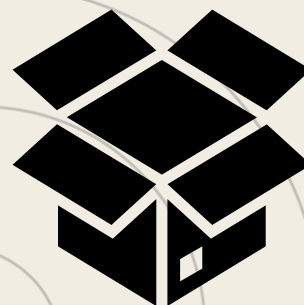
The mitigations associated with this category are: AML.M0026 Privileged AI Agent Permissions Configuration, AML.M0027 Single-User AI Agent Permissions Configuration, AML.M0033 AI Agent Tools Permissions Configuration, AML.M0030 Restrict AI Agent Tool Invocation on Untrusted Data, AML.M0029 Human in the Loop, AML.M0032 Segmentation of AI Agents and Components, AML.M0006 Use Ensemble Methods.

What effort is associated with remediations in this category?

These efforts consist of actions taken to prevent the abuse of a model from malicious requests intending to gain extraneous access to possible capabilities regarding your system. The efforts required will be of medium workload as alteration of current system code will likely be required.

How does this facilitate the remediation process?

This facilitates remediation by identifying processes associated with the vulnerable attack surfaces relevant to applicable mitigation strategies.



Processing Sanitization

What is this category?

Output sanitization is the action of remediating processes associated with data output on a given AI/LLM System.

What Mitigation IDs are associated with this category?

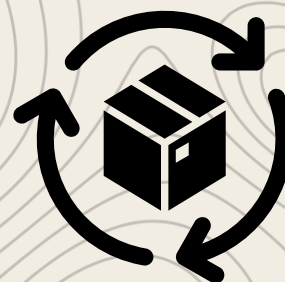
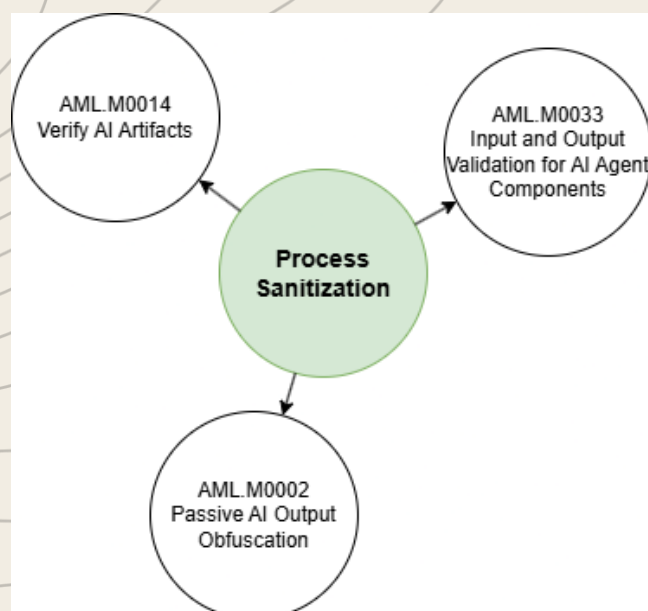
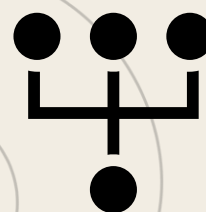
The mitigations associated with this category are: AML.M0014 Verify AI Artifacts, AML.M0002 Passive AI Output Obfuscation, AML.M0033 Input and Output Validation for AI Agent Components.

What effort is associated with remediations in this category?

Most forms of compromise that require output sanitization efforts imply that Access Gain is possible; the tactics utilized here generally have progressed to a state in which a prompt creates a malicious output. This implies a medium-difficult level of effort, as not only does your system hosting your model need remediations but it must be done so in a timely fashion.

How does this facilitate the remediation process?

This facilitates remediation by identifying processes associated with the vulnerable attack surfaces relevant to applicable mitigation strategies.



Output Sanitization

What is this category?

Output sanitization is the action of remediating processes associated with data output on a given AI/LLM System.

What Mitigation IDs are associated with this category?

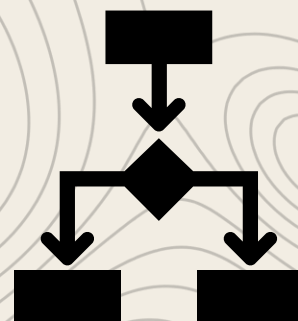
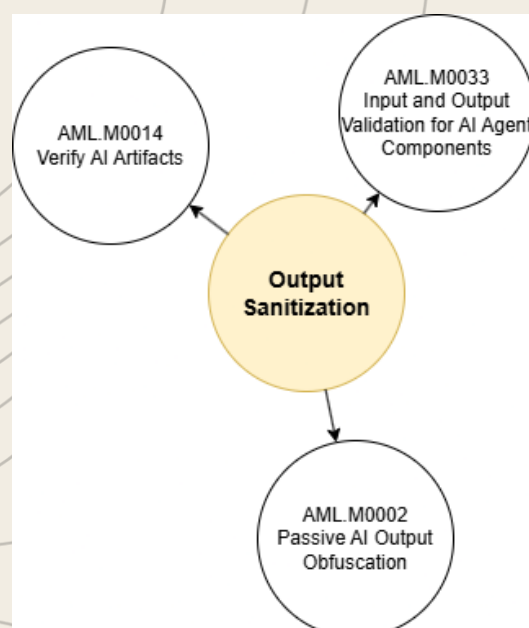
The mitigations associated with this category are: AML.M0014 Verify AI Artifacts, AML.M0002 Passive AI Output Obfuscation, AML.M0033 Input and Output Validation for AI Agent Components.

What effort is associated with remediations in this category?

Most forms of compromise that require output sanitization efforts imply that Access Gain is possible; the tactics utilized here generally have progressed to a state in which a prompt creates a malicious output. This implies a medium-difficult level of effort, as not only does your system hosting your model need remediations but it must be done so in a timely fashion.

How does this facilitate the remediation process?

This facilitates remediation by identifying processes associated with the vulnerable attack surfaces relevant to applicable mitigation strategies.



Model Hardening

What is this category?

Model Hardening Remediations consist of efforts which intend to improve model outputs by adjusting the internal model configurations, model file level parameters, or request schema of a given model used.

What Mitigation IDs are associated with this category?

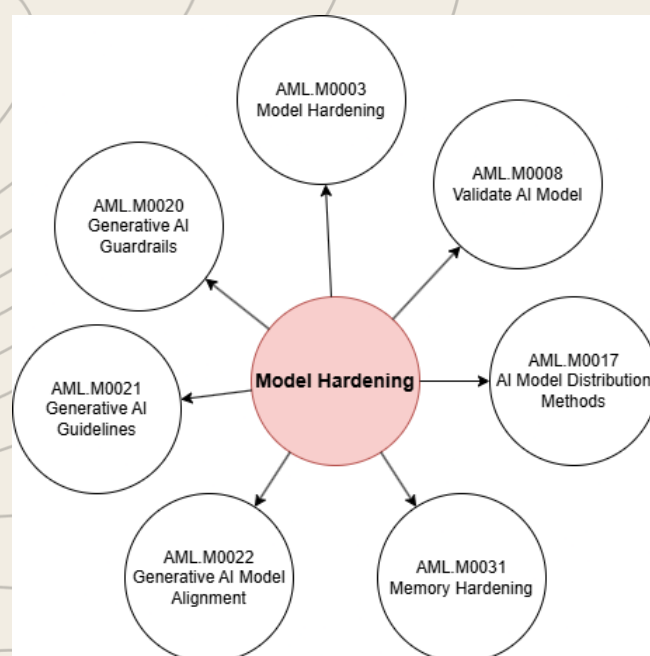
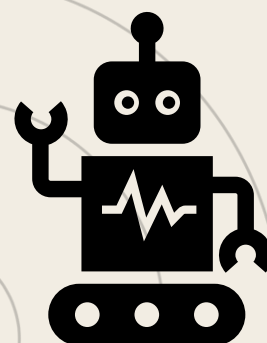
The mitigations associated with this category are: AML.M0020 Generative AI Guardrails, AML.M0021 Generative AI Guidelines, AML.M0022 Generative AI Model Alignment, AML.M0031 Memory Hardening, AML.M0003 Model Hardening, AML.M0008 Validate AI Model, AML.M0017 AI Model Distribution Methods.

What effort is associated with remediations in this category?

Time spent can range from as little as editing a model file or API request structure, to as much as generating or distilling a completely new model. Testing must occur to rectify issues within this category.

How does this facilitate the remediation process?

This facilitates remediation by identifying processes associated with the vulnerable attack surfaces relevant to applicable mitigation strategies.



System Monitoring

What is this category?

System Monitoring Remediations are remedial measures targeting the underlying monitoring systems which operate when the AI/LLM System is running.

What Mitigation IDs are associated with this category?

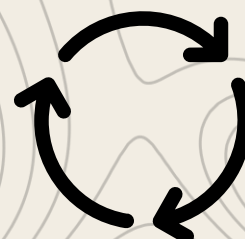
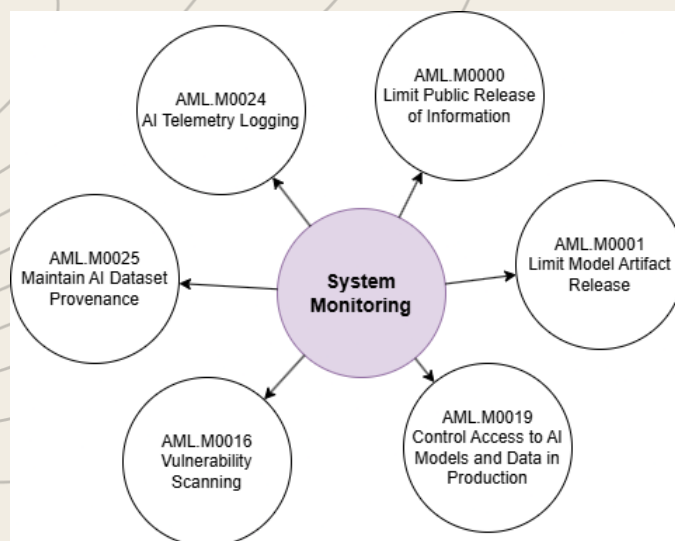
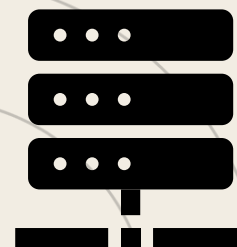
The mitigations associated with this category are AML.M0024 AI Telemetry Logging, AML.M0025 Maintain AI Dataset Provenance, AML.M0016 Vulnerability Scanning, AML.M0000 Limit Public Release of Information, AML.M0001 Limit Model Artifact Release, AML.M0019 Control Access to AI Models and Data in Production

What effort is associated with remediations in this category?

Mitigation efforts are generally implementations to existing systems with already existing solutions, providing a benefit to engineers.

How does this facilitate the remediation process?

This facilitates remediation by identifying processes associated with the vulnerable attack surfaces relevant to applicable mitigation strategies.



Conclusion

CAIRS values are assigned to findings to set the tone behind any conversation pertaining to remediation. The composite score determines the overall impact the finding has on your organization, with a simple and easy to understand value determining the impact of your team's findings. The scores generated, to influence the composite score, are what determine how you delegate and prioritize remediation efforts. These scores are all derived from the implicit relationships existing between Threat IDs, Mitigations, and Tactics. The presence of compromise per Threat IDs can be tested for by Red Team Techniques defined by your team and other researchers. The values generated in a CAIRS score are the byproduct of Red Team Interventions and adversarial emulation. The findings from testing continuously shape the security posture of a given model over its life span, and provide direction to teams involved with remediation.